

Relatório de Segurança — ERP Flow

Relatório

Versão 4.2 — atualização do V4.1, com anexos de evidências

Referência	Informação
Data-base	28/09/2026
Base de código	Commit ff8676ddb80e · ERP Flow
Método	Revisão de código e testes locais registrados. Sem nova consulta ao banco de produção ou ao SAP.
Classificação	Confidencial — Uso Interno
Leitura	Páginas 1–4: resumo e decisões. Anexos A–J: trechos reais do código e resultados de testes.

1. Sumário executivo

As correções avançaram nos acessos por empresa, validação de sessão, MFA, documentos fiscais e limpeza de dados ao sair do sistema. Também foram tratados **quatro novos achados**: integrações sem checagem de permissão, notas canceladas ou rejeitadas reprocessadas, criação de rascunhos duplicados e identificação do responsável informada pelo próprio solicitante.

O código foi corrigido e os cenários descritos passaram nos testes locais. A confirmação no ambiente utilizado pela operação ainda está pendente. Por isso, esta atualização não repete a conclusão de que todos os riscos críticos estão encerrados.

Correções Testadas localmente	Ambiente de operação Validação pendente	Rotação, backup e TLS Pendências abertas
----------------------------------	--	---

O que mudou para o negócio

- O usuário precisa ter permissão para a **empresa e a operação** que está tentando executar.
- Uma nota cancelada ou rejeitada não deve voltar a gerar rascunho no SAP pelo reprocessamento.
- Se houver dúvida sobre o resultado no SAP, o sistema procura o documento antes de tentar criar outro.
- A reaprovação de despesas recebeu ajuste para reenviar o conteúdo aprovado e conferir os valores, em seção separada de segurança.

Para liberar: aplicar as migrações necessárias, conferir os acessos legítimos e testar os fluxos no ambiente de homologação. Rotação de senhas/chaves, restauração de backup e TLS continuam exigindo evidência própria.

Os anexos mostram o trecho que implementa cada controle e o teste correspondente. Eles não substituem a validação no ambiente publicado. Nenhum encerramento operacional é declarado nesta emissão.

2. Situação dos achados originais (F01–F15)

Relatório

A severidade é a do relatório original. **“Corrigido localmente” não significa “encerrado em produção”**. Estados atualizados com base nas correções e evidências do repositório.

ID	Achado	Sev.	Situação atual	Atualização / evidência
F01	Cadastro / domínio	Crítico	A confirmar	Validação no servidor existe. Configurações e contas do ambiente publicado precisam ser reconferidas.
F02	Identidade da sessão SAP	Crítico	Corrigido localmente	Assinatura e validade conferidas em toda chamada, mesmo após acesso anterior. Anexo A.
F03	Uso da conta de serviço SAP	Crítico	Cobertura a confirmar	Controle original do proxy preservado. Falta conferir outros consumidores e privilégios reais da conta.
F04	Exceção de aprovação PagCorp	Crítico	Parcial	Texto livre não autoriza; criação exige permissão na empresa. Homologar o fluxo completo. Anexo B.
F05	CNAB / dados bancários	Crítico	Parcial	Cada ação exige sua permissão; falta retestar dupla aprovação, integridade e repetição de retorno. Anexo B.
F06	Segredos expostos	Crítico	Rotação pendente	Cifra existente não prova troca/revogação das credenciais anteriormente expostas.
F07	Backup e recuperação	Alto	Restore pendente	Ainda falta demonstrar restauração completa, incluindo autenticação e chaves.
F08	HANA / Service Layer sem TLS	Alto	Aberto / terceiros	Exigir TLS e restrição de rede; depende de infraestrutura e fornecedor.
F09	MFA administrativo	Alto	Parcial	Recusa não escapa pelo acesso SAP; reset exige outro admin e auditoria. Anexos A/C.
F10	Copiloto / SQL	Alto	Parcial	Confirmações isoladas por chamada; privilégios SQL e cobertura das ferramentas pendentes. Anexo C.
F11	Autoria / isolamento	Alto	Parcial	Empresa e ação passam a ser exigidas nas rotas tratadas; autoria verificada. Anexos B/E.
F12	Impersonação somente leitura	Médio	Parcial	Falha de consulta não libera escrita; falta matriz completa de rotas e banco. Anexo A.
F13	Dados locais após logout	Médio	Parcial	Limpeza aguarda conclusão e fila confere o dono. Corridas e divisão por empresa pendentes. Anexo D.
F14	IA / privacidade	Médio	Aberto / parcial	Mascaramento, formatos, retenção e aprovação do provedor continuam pendentes.
F15	Inventário e agendamentos	Médio	Parcial	Dois agendadores protegidos; inventário global e revisão de contas ainda pendentes. Anexo E.

Leitura em relação ao V4.1: a revisão encontrou falhas residuais em pontos antes classificados como fechados. Os controles foram ampliados; onde o teste publicado ou a cobertura ainda faltam, a situação permanece parcial.

3. Pendências e plano de conclusão

Relatório

Item	Ação necessária	Referência de prazo
F06	Trocar e revogar credenciais expostas; registrar responsáveis e comprovação.	30 dias no V4.1
F07	Executar uma restauração completa e comprovar dados, autenticação e recuperação das chaves.	30 dias no V4.1
F08	Obter TLS no HANA e restrição de acesso ao Service Layer com infraestrutura/Wevy.	Dependência externa
F10/F11	Conferir permissões do copiloto e os grupos por empresa; completar a cobertura das rotas.	15/30 dias no V4.1
F13	Concluir troca de conta/empresa entre abas, gravações tardias e chamadas já iniciadas.	15 dias no V4.1
F14	Aprovar política de classificação, mascaramento e retenção dos dados enviados à IA.	60 dias no V4.1
Extra	Revisar acesso direto a tabelas/funções, dependências efetivas e inventário de serviços.	60 dias para policieis no V4.1
N01–N04	Aplicar migrações 0063/0064 antes dos serviços dependentes; retestar acessos, estado da nota e duplicidade.	Priorizar na homologação
FUNC-01	Repetir no SAP o ciclo: aprovar → integrar → editar → reaprovar → conferir conteúdo e valores.	Antes de liberar o ajuste

Os prazos acima são a referência do V4.1, **não novos compromissos ou prazos reiniciados**. Responsáveis nominais e datas de aceite ainda precisam ser definidos. O backlog detalhado B01–B20 permanece no repositório.

4. Nota de integridade dos relatórios anteriores

As descrições F16–F20 dos anexos V4.0 não corresponderam suficientemente aos arquivos e objetos conferidos. Não são contabilizadas como cinco correções adicionais. As classes de risco continuam em revisão: arquivos, integrações externas, mensagens de erro, MFA e acesso ao banco.

Também foram revistas interpretações: quantidade de fatores MFA não prova exigência em cada ação; backup executado não comprova restauração; tabela com proteção de acesso não limita automaticamente um serviço privilegiado. A cifra de `system_credentials` observada foi PGP/AES-256, e não a descrição genérica AES-GCM repetida nos relatórios.

A recomendação antiga de “aceitar o risco” de TLS não equivale a aceite do responsável. Nenhuma aceitação formal de risco está anexada.

5. Novos achados e correções desta atualização

Relatório

ID	Problema encontrado	Correção e situação
N01 Alta	Serviços podiam iniciar integrações sem conferir quem chamou e em qual empresa podia operar.	Autenticação e permissão por empresa/ação nas três rotas; dois agendadores também protegidos. Testes locais passaram. Anexo E.
N02 Alta	Nota cancelada ou rejeitada podia voltar ao SAP pelo reprocessamento por ID.	Estados proibidos são bloqueados e reconferidos no banco ao reservar a execução. Testes locais passaram. Anexo F.
N03 Alta	Duas chamadas simultâneas podiam criar dois rascunhos para a mesma nota.	Reserva única e reconciliação do resultado incerto, sem novo envio automático. Testes locais/SQL passaram. Anexo G.
N04 Média	O solicitante podia informar o email do responsável no registro da sincronização.	Responsável passa a vir da identidade verificada; a informação enviada pelo usuário não substitui a autoria. Anexo E.

N01 e N04 compartilham uma rota; N01–N03 podem compor uma mesma sequência de falhas. Os quatro IDs representam causas distintas, não quatro ataques comprovados em produção. A sincronização de colaboradores continua limitada às bases TST.

6. Ajuste funcional — reaprovação de despesas

Relato: despesa já integrada era editada e, ao ser aprovada novamente, chegava ao SAP com valores zerados. O envio agora exige a leitura completa do documento, preserva campos editáveis e identificadores das linhas e confere os preços após a atualização.

O teste simulou o SAP zerando o primeiro envio; a correção posterior confirmou **2 × 506,50 = 1.013,00**, mantendo os demais campos previstos. A ocorrência real e as particularidades do SAP/add-ons ainda precisam ser homologadas. Anexos H/I.

Como ler os anexos

Cada anexo traz **problema** → **correção** → **trecho literal** → **resultado do teste** → **limite**. Arquivo, linhas e commit permitem localizar a prova. Resultados são das execuções registradas; não foram produzidos novos testes só para gerar este PDF.

Código e resultados não comprovam publicação. O registro de liberação deve identificar versão implantada, data, responsável e teste no ambiente utilizado pela operação.

Anexo A — Sessão SAP, MFA e impersonação

Evidência de correção · F02/F09/F12

Problema: uma validação anterior em memória podia dispensar a prova atual da sessão. Uma recusa no acesso Cloud também podia ser contornada pela alternativa SAP.

Antes — baseline V4.1 · supabase/functions/_shared/auth.ts · L642–643

```
642   const cached = sapSessionValidationCache.get(cacheKey);
643   if (cached && cached.expiresAt > Date.now()) return cached.value;
```

Código atual · supabase/functions/_shared/auth.ts · L570–579

```
570   if (tokenPayloadHasSub(bearer)) await requireUser(req);
571   const headers = parseSapHeaders(req);
572   if (!headers) return null;
573   const { sapSession, sapUser, companyDB, sapAuthToken } = headers;
574   let signed: SapSessionValidation | null;
575   try {
576     signed = await verifySapAuthToken(sapAuthToken, sapSession, sapUser, companyDB);
577   } catch { return null; }
578   // HMAC e expiração são baratos e obrigatórios em TODAS as chamadas.
579   if (!signed) return null;
```

Código atual · supabase/functions/_shared/auth.ts · L586–590

```
586   if (deprovision.error || typeof deprovision.data !== "boolean") throw new Error("security lookup
failed");
587   if (revoked || deprovision.data) return null;
588   } catch {
589     throw new AuthError("Não foi possível verificar a sessão ERP. Tente novamente.", 503);
590   }
```

Saída registrada do teste

✓ SAP: valid proof works, missing/expired proof is denied after a successful call (36.287917ms)

[Abrir evidência completa](#)

Saída registrada do teste

✓ Cloud MFA rejection cannot fall back to SAP; authorized AAL2 still works (3.613875ms)

[Abrir evidência completa](#)

O que demonstra: A prova e a validade são verificadas a cada acesso. Uma identidade Cloud apresentada precisa continuar atendendo a seus controles; falha na consulta de segurança bloqueia a sessão.

O que falta: Confirmar esses comportamentos no serviço publicado e medir o impacto de mais consultas de segurança. Cobertura integral de impersonação e prazo das sessões permanece pendente.

Anexo B — Permissão na empresa e na operação

Evidência de correção • F04/F05/F11 e documentos fiscais

Correção: ter acesso de leitura não deve permitir gerar, aprovar ou integrar documentos. A empresa autorizada deve ser a do recurso que será usado.

Código atual · supabase/functions/accounts-payable-cnab/index.ts · L1661–1669

```
1661 const actions = {
1662   get_config: "view", get_supplier_payment_profile: "view", list_open: "view", list_batches: "view",
1663   preview_return: "view", save_config: "edit", save_supplier_payment_profile: "edit",
1664   generate: "create", approve_batch: "approve", approve_supplier_payment_profile: "approve",
1665   download_batch: "export", process_return: "integrate",
1666 } as const;
1667 if (!Object.hasOwn(actions, action)) return json({ error: "Ação inválida." }, 400);
1668 let auth: Record<string, unknown>;
1669 try {
```

Código atual · supabase/functions/_shared/auth.ts · L498–503

```
498   if (scope && !companyDb) throw new AuthError("Configuração global exige administrador", 403);
499   const { data } = await svcClient().rpc("has_module_action", {
500     _user_id: u.id, _company_db: companyDb, _module: moduleKey, _action: scope?.action ?? "view",
501   });
502   if (data === true) return { ...u, ...(scope ? { companyDB: companyDb! } : {}), source:
"cloud_module" as const };
503 } catch { /* segue para sessão ERP */ }
```

Código atual · supabase/functions/nf-entrada-fetch-file/index.ts · L118–124

```
118   await requireAdminOrSapModule(req, "nf_entrada", { companyDb: row.sap_company_db, action: "view"
});
119   const existingPath = kind === "xml" ? row.xml_storage_path : row.pdf_storage_path;
120   if (existingPath) {
121     const { data: signed, error: signErr } = await supabase.storage
122       .from("nf-entrada-files").createSignedUrl(existingPath, 60 * 10);
123     if (!signErr && signed?.signedUrl) {
124       return new Response(JSON.stringify({ url: signed.signedUrl, cached: true }), {
```

Saída registrada do teste

✓ CNAB dispatcher requires the matching action on the body company for every operation (12.732542ms)

[Abrir evidência completa](#)

O que demonstra: O CNAB mapeia operações para permissões distintas. O guard consulta a empresa e a ação. Para o documento fiscal, a permissão é conferida antes de emitir o link de download.

O que falta: A rotina financeira completa, grupos reais, download pelo provedor e demais consumidores exigem homologação. A migração 0063 deve preceder as funções dependentes.

Anexo C — Confirmações de IA e reset de MFA

Evidência de correção • F09/F10

Correção do copiloto: o responsável e o cliente de banco seguem no contexto da chamada; não ficam em variáveis globais compartilhadas entre solicitações.

Código atual · supabase/functions/copilot-chat/index.ts · L395–396

```
395   ctx = { ...ctx, pendingSb: sb, pendingActor: actor };
396   if (!WRITE_TOOL_NAMES.has(name)) ctx = { ...ctx, confirmed: false };
```

Código atual · supabase/functions/copilot-chat/index.ts · L353–357

```
353   const { pendingSb, pendingActor } = ctx;
354   if (!pendingSb || !pendingActor) return { error: "Confirmação indisponível." };
355   const { confirmed: _ignored, ...cleanArgs } = args || {};
356   const { data, error } = await pendingSb.from("copilot_pending_actions").insert({
357     user_id: pendingActor.userId, tool_name: name, args: cleanArgs, summary: summary.slice(0, 1000),
```

Saída registrada do teste

✓ Copilot pending confirmation remains owned by its request during interleaving (1.133584ms)

[Abrir evidência completa](#)

Correção do reset: o administrador não redefine seu próprio MFA por essa função, e a auditoria inicial precisa funcionar antes da remoção.

Código atual · supabase/functions/mfa-admin-reset/index.ts · L58–64

```
58     if (target === actor.id) return json({ error: "Solicite a redefinição a outro administrador." },
403);
59     const { error: auditStartError } = await svc.rpc("insert_audit_log", {
60       p_action: "mfa_factor_reset_requested", p_entity_type: "user", p_entity_id: target,
61       p_actor_email: actor.email, p_company_db: null, p_details: { self_reset: false },
62     });
63     if (auditStartError) return json({ error: "Auditoria indisponível; nenhum fator foi removido."
}, 503);
64     const { data: list, error: lerr } = await svc.auth.admin.mfa.listFactors({ userId: target });
```

Saída registrada do teste

✓ MFA reset: self denied, audit failure blocks deletion, successful reset is audited (3.570791ms)

[Abrir evidência completa](#)

O que demonstra: Os testes preservam o dono da confirmação e impedem remover fatores quando a auditoria inicial falha. Há limite de 10 tentativas por 15 minutos por administrador, com bloqueio se o contador falhar.

O que falta: Permissões SQL e demais ferramentas do copiloto continuam pendentes. No MFA, falha da auditoria final pode ocorrer após remoção; isso é informado como falha parcial e exige conferência.

Anexo D — Limpeza no logout e dono da fila

Evidência de correção • F13

Problema: o sistema iniciava a exclusão dos bancos locais sem aguardar o resultado. A fila podia continuar com uma lista capturada antes da troca de usuário.

Código atual · [src/lib/clear-erp-local-state.ts](#) · L56–67

```
56 export async function clearUserIndexedDBs(): Promise<void> {
57   if (typeof indexedDB === "undefined") return;
58   const results = await Promise.allSettled(USER_INDEXED_DBS.map((name) => new Promise<void>((resolve,
    reject) => {
59     const req = indexedDB.deleteDatabase(name);
60     const timer = setTimeout(() => reject(new Error("Não foi possível limpar os dados locais. Feche as
    outras abas do ERP e tente novamente.")), 5000);
61     req.onsuccess = () => { clearTimeout(timer); resolve(); });
62     req.onerror = () => { clearTimeout(timer); reject(req.error ?? new Error("Falha ao limpar os dados
    locais")); });
63     // onblocked não conclui a operação: aguarda as outras conexões fecharem.
64   }));
65   const failed = results.find((r): r is PromiseRejectedResult => r.status === "rejected");
66   if (failed) throw failed.reason;
67 }
```

Código atual · [src/lib/offline-outbox.ts](#) · L255–263

```
255   if (entry.ownerId !== await getLocalOwnerId()) {
256     // Libera apenas o item reservado por este flush, sem enviá-lo.
257     await mutateOwnedEntry(entry.id, entry.ownerId, (current) => ({ ...current, status:
    "pending" }));
258     result.skipped += 1;
259     continue;
260   }
261   await sender(entry);
262   await removeOutbox(entry.id);
263   result.sent += 1;
```

Resultado registrado no Chrome

Cenário	Resultado
Outra conta tenta listar/alterar/excluir item	Dado do dono original preservado
Conta muda durante o processamento	Sem envio; dono original consegue retomar
Outra aba mantém conexão aberta	Espera pelo fechamento ou informa timeout
Limpeza e recarga da página	Bancos removidos; tema mantido; fila volta a funcionar

Evidência dos 5 cenários em IndexedDB real

O que demonstra: A exclusão só é confirmada quando termina. Antes do envio, a fila confere novamente quem está conectado.

O que falta: Separação dos rascunhos por empresa, gravações tardias, troca rápida entre abas e requisições já iniciadas continuam abertas.

Anexo E — Quem pode integrar e quem fica registrado

Evidência de correção · N01/N04

Correção: as rotas N01 autenticam o solicitante antes de consultar dados e depois conferem a permissão na empresa do recurso. Agendadores exigem identidade técnica, sem confiar em um nome de usuário no corpo.

Código atual · [supabase/functions/_shared/integration-auth.ts](#) · L22–27

```
22 export async function authorizeIntegrationCompany(
23   req: Request, caller: IntegrationCaller, module: string, companyDb: string | null,
24 ): Promise<void> {
25   if (!companyDb) throw new AuthError("Empresa do recurso não informada", 400);
26   if (!caller.technical) await requireAdminOrSapModule(req, module, { companyDb, action: "integrate"
27   });
28 }
```

Código atual · [supabase/functions/employees-sync-run/index.ts](#) · L49–49

```
49   await authorizeIntegrationCompany(req, caller, "employee_integration", companyDb);
```

Código atual · [supabase/functions/employees-sync-run/index.ts](#) · L75–79

```
75     execution_type: executionType,
76     status: "running",
77     triggered_by: caller.userId,
78     triggered_by_email: caller.actor,
79   })
```

Código atual · [supabase/functions/_shared/integration-auth.ts](#) · L14–19

```
14   const user = await requireUserOrSapSession(req);
15   return {
16     technical: false,
17     userId: user.id.startsWith("sap:") ? null : user.id,
18     actor: user.email || user.id,
19   };
```

Saída registrada do teste

✓ N01: anonymous cannot reach DB or ERP in three handlers and their two scheduler endpoints (53.468875ms)

[Abrir evidência completa](#)

Saída registrada do teste

✓ N04: employees derive actor and execution type from identity; spoofed body never becomes audit author (4.890375ms)

[Abrir evidência completa](#)

O que demonstra: O usuário não escolhe a identidade gravada na execução. O teste nega chamadas sem identidade antes de banco/ERP nas três rotas e nos dois agendadores.

O que falta: Conferir os grupos, o agendamento real e o acesso pelo gateway. A credencial de serviço ainda é ampla; rotação e menor privilégio continuam pendentes.

Anexo F — Nota cancelada ou rejeitada não é reaberta

Evidência de correção • N02

Correção: a regra de elegibilidade passou para o fluxo comum, incluindo solicitações por ID. O banco confere o estado atual antes de aceitar a reserva.

Código atual · supabase/functions/_shared/nf-draft-once.ts · L44–51

```
44 export function assertNfDraftEligible(row: { status: string; sap_po_draft_id: string | null }): void {
45   if (["cancelled", "erpflow_rejected", "sap_rejected", "completed"].includes(row.status)) {
46     throw new AuthError("Estado da NF não permite criar ou reprocessar Draft", 409);
47   }
48   if (!row.sap_po_draft_id && !["pending_expense", "integration_error"].includes(row.status)) {
49     throw new AuthError("NF não está elegível para integração", 409);
50   }
51 }
```

Código atual · drizzle/migrations/0064_nf_po_draft_idempotency.sql · L19–24

```
19 SELECT status INTO current_status FROM public.nf_entrada_imports WHERE id = NEW.import_id FOR
  UPDATE;
20 IF current_status IS NULL OR current_status NOT IN ('pending_expense', 'integration_error') THEN
21   RAISE EXCEPTION 'NF não elegível para criação de Draft' USING ERRCODE = '23514';
22 END IF;
23 RETURN NEW;
24 END;
```

Código atual · drizzle/migrations/0064_nf_po_draft_idempotency.sql · L34–39

```
34 IF NEW.status IS DISTINCT FROM OLD.status
35   AND NEW.status IN ('cancelled', 'erpflow_rejected', 'sap_rejected', 'completed')
36   AND EXISTS (SELECT 1 FROM public.nf_po_draft_jobs WHERE import_id = OLD.id AND state IN
  ('processing', 'uncertain')) THEN
37   RAISE EXCEPTION 'Reconcilie a integração em andamento antes de alterar o estado da NF' USING
  ERRCODE = '23514';
38 END IF;
39 RETURN NEW;
```

Saída registrada do teste

✓ N01/N02: wrong company, cancelled/rejected/completed notes and unprivileged batch cause no write (13.612209ms)

[Abrir evidência completa](#)

O que demonstra: Cancelada, rejeitada no Flow/SAP e concluída são recusadas. Durante criação de resultado incerto, a transição de cancelamento/rejeição aguarda reconciliação para não ocultar um documento já criado no ERP.

O que falta: Reabertura de uma rejeição exige processo autorizado separado. Validar as transições concorrentes com o processo real. Um rascunho SAP não é um pagamento executado.

Anexo G — Uma nota não deve criar dois rascunhos

Evidência de correção • N03

Correção: uma reserva única no banco impede duas criações simultâneas. Se a resposta do SAP se perder, o próximo passo é localizar o documento, não repetir o envio.

Código atual · [drizzle/migrations/0064_nf_po_draft_idempotency.sql](#) · L2–10

```
2 CREATE TABLE public.nf_po_draft_jobs (
3   import_id uuid PRIMARY KEY REFERENCES public.nf_entrada_imports(id) ON DELETE RESTRICT,
4   state text NOT NULL CHECK (state IN ('processing', 'uncertain', 'completed')),
5   token uuid NOT NULL,
6   draft_id text,
7   updated_at timestamptz NOT NULL DEFAULT now(),
8   CHECK (state <> 'completed' OR draft_id IS NOT NULL)
9 );
10 ALTER TABLE public.nf_po_draft_jobs ENABLE ROW LEVEL SECURITY;
```

Código atual · [supabase/functions/_shared/nf-draft-once.ts](#) · L17–23

```
17   if (job.state === "completed" && job.draft_id) return job.draft_id;
18   if (job.state !== "uncertain") throw new AuthError("NF em processamento; não repita a criação. Se
o processo foi interrompido, solicite reconciliação.", 409);
19   const { data: claimed, error: claimError } = await db.from("nf_po_draft_jobs")
20     .update({ state: "processing", token, updated_at: new Date().toISOString() })
21     .eq("import_id", importId).eq("state", "uncertain").select("import_id").maybeSingle();
22   if (claimError || !claimed) throw new AuthError("NF já está em reconciliação", 409);
23   reconcileOnly = true;
```

Código atual · [supabase/functions/_shared/nf-draft-once.ts](#) · L26–29

```
26   const found = await reconcile();
27   if (!found && reconcileOnly) throw new AuthError("Resultado anterior ainda incerto; não será
criado outro Draft. Reconciliação necessária.", 409);
28   const draftId = found || await create();
29   if (!draftId || !/^\d+$/.test(draftId)) throw new Error("SAP não confirmou um DocEntry válido");
```

Saída registrada do teste

✓ N03: ambiguous POST reconciles an existing Draft without issuing a second POST (2.074459ms)

[Abrir evidência completa](#)

Saída registrada do teste

✓ N03: SAP success followed by local completion failure reconciles without duplicate creation (3.093542ms)

[Abrir evidência completa](#)

O que demonstra: O ID da nota é único na reserva. Resultado concluído é reutilizado; incerto só permite reconciliação. Duas conexões reais ao PostgreSQL também foram testadas: apenas uma reservou a execução.

O que falta: Processo interrompido pode exigir intervenção. Não apagar reserva por tempo decorrido. Rascunhos antigos, sem a nova correlação, precisam ser reconciliados antes da liberação.

Anexo H — A reaprovação envia o documento completo

Evidência funcional · FUNC-01 · fora da contagem de segurança

Problema funcional: valores zerados após editar e reaprovar uma despesa integrada. A leitura das linhas podia falhar e o código continuar com dados incompletos.

Antes — falha de leitura era ignorada · [supabase/functions/_shared/sap-line-merge.ts](#) · L125–131

```
125 let current: Record<string, unknown>[] = [];  
126 try {  
127   current = await readSapDocumentLines(baseUrl, cookies, endpoint, docEntry);  
128 } catch {  
129   current = [];  
130 }  
131 return mergeSapDocumentLines(current, desiredLines);
```

Código atual · [supabase/functions/_shared/sap-line-merge.ts](#) · L140–145

```
140 const res = await fetch(`${baseUrl}/${endpoint}(${docEntry})`, { headers: { Cookie: cookies } });  
141 if (!res.ok) throw new Error(`Não foi possível ler o documento completo antes do PATCH  
[${res.status}]`);  
142 const current = await res.json();  
143 if (!Array.isArray(current.DocumentLines) || !Array.isArray(desired.DocumentLines) ||  
!desired.DocumentLines.length) {  
144   throw new Error("Documento sem coleção completa de linhas; PATCH cancelado");  
145 }
```

Código atual · [supabase/functions/_shared/sap-line-merge.ts](#) · L150–154

```
150 for (const key of Object.keys(current)) if (key.startsWith("U_")) payload[key] = current[key];  
151 Object.assign(payload, desired);  
152 for (const key of ["DocEntry", "DocNum", "DocTotal", "BPL_IDAssignedToInvoice", "DocDate",  
"TaxDate", "DocCurrency"]) delete payload[key];  
153 payload.DocumentLines = mergeSapDocumentLines(current.DocumentLines, desired.DocumentLines);  
154 return payload;
```

Código atual · [supabase/functions/expense-to-sap/index.ts](#) · L1741–1745

```
1741 const patchPayload = await buildFullDocumentPatch(  
1742   sap.baseUrl, sap.cookies, sap.Endpoint, patchDocEntry, sapPayload,  
1743 );  
1744 lastSapPayload = patchPayload;  
1745 const resp = await patchSapDocument(sap.baseUrl, sap.cookies, sap.Endpoint, patchDocEntry,  
  patchPayload);
```

O que demonstra: O PATCH depende de uma leitura válida. O conteúdo aprovado prevalece, campos personalizados são preservados e a coleção completa de linhas é montada antes do envio.

O que falta: “Completo” se refere aos campos editáveis: totais calculados, IDs, filial, moeda e datas contábeis originais não são reenviados. Não foi capturada a ocorrência real; não se afirma causa exclusiva sem homologação.

Anexo I — Preços e linhas conferidos após o envio

Evidência funcional · FUNC-01

Correção funcional: preservar IDs existentes evita confundir linhas depois de exclusões. O valor aprovado é reenviado nos campos de preço e depois conferido no SAP.

Código atual · supabase/functions/_shared/sap-line-merge.ts · L102–111

```
102   if (current && Number.isInteger(Number(current.LineNum))) merged.LineNum =
      Number(current.LineNum);
103   else delete merged.LineNum;
104   // Preço aprovado sempre nos dois campos – o SAP lê ora um, ora outro.
105   const price = Number(desired.UnitPrice ?? desired.Price ?? merged.UnitPrice ?? merged.Price);
106   if (Number.isFinite(price) && price >= 0) {
107     merged.UnitPrice = price;
108     merged.Price = price;
109   }
110   // Item trocado: descrição/unidade do item antigo não devem ser herdadas.
111   if (current && String(current.ItemCode ?? "") !== String(merged.ItemCode ?? "")) {
```

Código atual · supabase/functions/_shared/sap-line-prices.ts · L57–59

```
57   if (!actual) throw new Error("SAP não retornou uma das linhas aprovadas");
58   return { ...e, lineNum: Number(actual.LineNum) };
59   });
```

Saída registrada do teste

✓ Expense reapproval: real payload builder and PATCH pipeline preserve complete approved content and repair zero SAP prices (3.6265ms)

[Abrir evidência completa](#)

Teste reproduzível — asserção do valor aprovado

Teste: $2 \times 506,50 = 1.013,00$ · src/lib/sap-document-patch.test.ts · L39–39

```
39   expect(lines[0].Quantity*lines[0].UnitPrice).toBe(1013);
```

O que demonstra: O ensaio usa o código real de montagem e envio, simula o primeiro PATCH com preço zero e confirma a correção posterior, mantendo cabeçalho, anexo, campos personalizados e linha.

O que falta: Homologar impostos, unidades, add-ons, linhas gratuitas e documentos encerrados. Associação das linhas existentes permanece posicional; o teste local não comprova o comportamento de todas as bases SAP.

Anexo J — Resultados, origem e limites das evidências

Relatório

Verificação	Resultado registrado
Segurança — primeira rodada	15 testes passaram
SQL de permissões — primeira rodada	14 verificações passaram
Logout — navegador Chrome	5 cenários passaram
V4.2 — rotas, autoria e fluxo de reaprovação	12 testes passaram
PATCH — testes específicos	6 testes passaram
SQL — reserva e concorrência de notas	6 cenários passaram
Build da aplicação	Passou; aviso anterior de arquivos grandes
Suíte geral	247 passaram, 49 ignorados, 1 falha anterior no teste de PDF
Tipos das quatro rotas centrais	25 erros antes/depois; sem novos diagnósticos. A verificação ainda falha.

Origem das evidências

Trechos extraídos literalmente dos arquivos, com numeração de linha. **Código atual:** commit ff8676ddb80e. **Antes:** baseline 410a28c9081c. Os arquivos completos estão nos links de cada anexo; os recortes e hashes ficam registrados no arquivo de integridade que acompanha este PDF.

[Resultados da primeira rodada](#) · [Resultados V4.2](#) · [Concorrência no PostgreSQL](#) · [Manifesto de arquivos V4.2](#)

O que não deve ser concluído a partir dos testes

Não somar as suítes como percentual de cobertura: há cenários sobrepostos. Nenhum teste remoto foi feito para esta emissão. As provas locais não atestam configuração de produção, TLS, restauração, privilégios reais do SAP ou encerramento de todas as brechas.

Critério para encerrar

Registrar versão implantada, migrações aplicadas, responsável e revisor, pedido/resposta sem dados sensíveis, efeito observado e teste positivo/negativo no ambiente correspondente. A publicação desta atualização não equivale ao aceite operacional.

Este PDF substitui a apresentação extensa da V4.2 para leitura executiva. O V4.1 permanece como histórico; alegações antigas de consulta “ao vivo” não são apresentadas como validações novas.